

PLATEFORME E-LEARNING ISO

Cours détaillés sur les normes ISO

ISO/IEC 27001 · ISO 9001

avec explications et exemples appliqués à Marsa Maroc

Projet : Plateforme e-learning adaptative

Organisme : Marsa Maroc — Port de Mohammedia

Structure : Cours → Chapitre → Sous-chapitre

Sommaire

Cours 1 — ISO/IEC 27001 : Sécurité de l'information

- 0. Fondamentaux de la sécurité de l'information
- 1. Contexte de l'organisation (clause 4)
- 2. Leadership (clause 5)
- 3. Planification (clause 6)
- 4. Support (clause 7)
- 5. Fonctionnement (clause 8)
- 6. Évaluation des performances (clause 9)
- 7. Amélioration (clause 10)
- 8. L'Annexe A — les 93 mesures

Cours 2 — ISO 9001 : Management de la qualité

- 0. Fondamentaux de la qualité
- 1. Contexte de l'organisation (clause 4)
- 2. Leadership (clause 5)
- 3. Planification (clause 6)
- 4. Support (clause 7)
- 5. Réalisation des activités opérationnelles (clause 8)
- 6. Évaluation des performances (clause 9)
- 7. Amélioration (clause 10)

Cours 1 — ISO/IEC 27001

Norme : ISO/IEC 27001:2022

Niveau : Intermédiaire

Pourquoi ce cours ? Un port pétrolier comme Mohammedia ne manipule pas seulement des hydrocarbures : il manipule aussi une énorme quantité d'informations sensibles — plannings d'accostage, quantités stockées, données douanières, contrats, systèmes de pilotage des pompes. Si ces informations sont volées, modifiées ou rendues indisponibles, les conséquences peuvent être graves : arrêt d'exploitation, accident, pertes financières, atteinte à la réputation. ISO 27001 apporte une méthode organisée pour protéger ces informations, expliquée ici clause par clause.

Chapitre 0 — Fondamentaux de la sécurité de l'information

Introduction

0.1 — Donnée vs information

Une **donnée** est un élément brut, sans contexte : le nombre « 45 000 » tout seul ne veut rien dire. Une **information** est une donnée mise en contexte qui acquiert un sens et une valeur : « le tank T3 contient 45 000 m³ de gasoil » est une information exploitable — et sensible. La sécurité de l'information ne protège pas les octets pour eux-mêmes, elle protège la valeur et le sens que ces données représentent.

Exemple Marsa Maroc : la liste brute des navires est une donnée ; reliée aux horaires, cargaisons et clients, elle devient une information stratégique qu'un concurrent ou un pirate aimerait obtenir.

0.2 — Le triangle DIC (le cœur de tout)

Toute la sécurité repose sur trois propriétés à préserver simultanément :

- **Disponibilité** — l'information doit être accessible au bon moment. Si le système de gestion des accostages tombe, le port s'arrête. Garantie par sauvegardes, redondance, onduleurs.
- **Intégrité** — l'information ne doit pas être modifiée sans autorisation. Altérer la quantité enregistrée dans une cuve peut provoquer un débordement. Protégée par contrôles d'accès, journaux, signatures.
- **Confidentialité** — seules les personnes autorisées y accèdent. Les contrats clients ne doivent pas fuiter. Assurée par chiffrement, mots de passe, classification.

0.3 — Vulnérabilité, menace, attaque, risque

Une **vulnérabilité** est une faiblesse ; une **menace** est un danger potentiel qui pourrait l'exploiter ; une **attaque** est la concrétisation de la menace ; le **risque** combine la probabilité et la gravité des conséquences.

Exemple Marsa Maroc : un poste informatique du quai laissé déverrouillé (vulnérabilité) peut être utilisé par un visiteur mal intentionné (menace) qui copie des données (attaque). Le risque est élevé si ce poste donne accès au système de gestion des cargaisons.

0.4 — Qu'est-ce qu'un SMSI ?

Le **Système de Management de la Sécurité de l'Information** est l'ensemble organisé des politiques, procédures, rôles et mesures techniques qui permettent de gérer la sécurité de façon systématique et continue, selon la logique **PDCA** (Planifier – Faire – Vérifier – Agir). ISO 27001 décrit comment construire ce SMSI.

Chapitre 1 — Contexte de l'organisation Clause 4

1.1 — Comprendre l'organisation et son contexte

Avant de protéger quoi que ce soit, il faut comprendre qui l'on est et dans quel environnement on évolue. L'organisation identifie ses enjeux internes (systèmes, culture, compétences) et externes (réglementation, menaces cyber du secteur portuaire, attentes de l'État). On ne protège pas de la même façon une PME et un port stratégique.

Exemple Marsa Maroc : entreprise publique gérant une infrastructure critique, soumise au code de sûreté ISPS, manipulant des produits dangereux — autant de facteurs qui élèvent le niveau d'exigence.

1.2 — Comprendre les besoins des parties intéressées

Une partie intéressée est toute entité ayant un intérêt dans la sécurité : clients, autorités (douane, ministère), employés, fournisseurs. Chacune a des attentes que le SMSI doit prendre en compte.

1.3 — Déterminer le périmètre du SMSI

On ne peut pas tout sécuriser d'un coup. L'organisation définit clairement les limites de son SMSI : quels sites, quels systèmes, quels processus. Un périmètre net évite les zones d'ombre et rend le système auditable.

Chapitre 2 — Leadership Clause 5

2.1 — Engagement de la direction

La sécurité n'est pas qu'une affaire de techniciens : c'est d'abord une décision de direction. Celle-ci doit s'impliquer activement, allouer des moyens, montrer l'exemple, intégrer la sécurité dans la stratégie. Sans engagement du sommet, un SMSI reste théorique.

Exemple Marsa Maroc : la direction qui inscrit la cybersécurité à l'ordre du jour de ses comités et débloque un budget dédié montre un engagement concret.

2.2 — La politique de sécurité de l'information

C'est le document fondateur : un texte de haut niveau, validé par la direction, fixant les grandes orientations et engagements. Il donne le cap que déclineront les procédures détaillées, et doit être communiqué à tous.

2.3 — Rôles, responsabilités et autorités

Chacun doit savoir qui fait quoi : qui est le responsable sécurité (RSSI), qui gère les accès, qui traite les incidents. Des responsabilités floues créent des trous de sécurité.

Chapitre 3 — Planification

Clause 6

3.1 — Appréciation des risques (le cœur d'ISO 27001)

L'étape la plus importante. On liste les actifs, on identifie menaces et vulnérabilités, on estime probabilité et gravité, puis on classe les risques du plus critique au plus mineur. C'est cette analyse qui détermine où concentrer les efforts.

Exemple Marsa Maroc : le risque « intrusion dans le système de pilotage des pompes » est très critique (accident possible), tandis que « perte de l'annuaire interne » est mineur.

3.2 — Traitement des risques

Pour chaque risque, on choisit une option : **réduire** (ajouter une mesure), **accepter** (si faible), **éviter** (supprimer l'activité) ou **transférer** (assurance, sous-traitance). On sélectionne ensuite les mesures de l'Annexe A.

3.3 — La Déclaration d'Applicabilité (SoA)

Document central qui liste toutes les mesures de l'Annexe A, indique lesquelles sont retenues ou exclues, et justifie chaque choix. C'est la carte d'identité du SMSI présentée à l'auditeur.

3.4 — Objectifs de sécurité

On fixe des objectifs mesurables (ex. « réduire de 50 % les incidents liés aux mots de passe en un an ») pour piloter la sécurité et mesurer les progrès.

Chapitre 4 — Support

Clause 7

4.1 — Ressources et compétences

Un SMSI a besoin de moyens (personnes, temps, outils, budget) et de personnes compétentes. Un responsable mal formé est lui-même une vulnérabilité.

4.2 — Sensibilisation et communication

La majorité des incidents viennent d'erreurs humaines. D'où l'importance de sensibiliser tout le personnel et d'organiser la communication sur la sécurité.

Exemple Marsa Maroc : former les agents à reconnaître un email de phishing réduit fortement le risque d'intrusion.

4.3 — Informations documentées

Le SMSI doit être documenté et ces documents maîtrisés (versionnés, protégés, accessibles, à jour). La documentation prouve que le système fonctionne — essentiel pour la certification.

Chapitre 5 — Fonctionnement Clause 8

5.1 — Planification et maîtrise opérationnelles

Phase « Faire » du PDCA : on met réellement en œuvre les processus et mesures prévus. La planification devient action concrète sur le terrain.

5.2 — Appréciation et traitement des risques en pratique

Les risques évoluent : de nouvelles menaces apparaissent. On réalise donc régulièrement les appréciations de risques, pas seulement pour l'audit. La sécurité est un processus vivant.

Chapitre 6 — Évaluation des performances Clause 9

6.1 — Surveillance, mesure, analyse

On ne peut améliorer que ce que l'on mesure. On suit des indicateurs (incidents, temps de réponse, mises à jour) pour évaluer l'efficacité du SMSI.

6.2 — Audit interne

Périodiquement, l'organisation vérifie elle-même que son SMSI est conforme et fonctionne, pour détecter les écarts avant l'audit externe.

6.3 — Revue de direction

La direction réexamine le SMSI à la lumière des résultats et prend des décisions. La boucle se referme : le leadership reste impliqué dans la durée.

Chapitre 7 — Amélioration Clause 10

7.1 — Non-conformités et actions correctives

Quand un écart est détecté, on le corrige **et** on agit sur sa cause profonde pour qu'il ne se reproduise pas. Traiter le symptôme ne suffit pas.

Exemple Marsa Maroc : après un cas de phishing, l'action corrective n'est pas seulement de nettoyer le poste, mais de renforcer la formation de toute l'équipe.

7.2 — Amélioration continue

Le SMSI n'est jamais « fini ». Dans la logique PDCA, on cherche en permanence à l'améliorer : nouvelles menaces, nouvelles technologies, retours d'expérience.

Chapitre 8 — L'Annexe A : les 93 mesures

Annexe A

L'Annexe A d'ISO 27001:2022 est un catalogue de **93 mesures** regroupées en 4 familles. L'organisation y pioche les mesures pertinentes selon son analyse de risques (via la SoA).

8.1 — A.5 Mesures organisationnelles (37 mesures)

Liées à l'organisation et à la gouvernance : politiques, rôles, gestion des accès, relations fournisseurs, gestion des incidents, classification de l'information, continuité d'activité. La plus grande famille.

Exemple Marsa Maroc : définir une politique de contrôle des accès aux systèmes portuaires, encadrer contractuellement les prestataires informatiques.

8.2 — A.6 Mesures liées aux personnes (8 mesures)

Concernent le facteur humain : vérifications avant embauche, sensibilisation, procédures disciplinaires, télétravail, confidentialité. L'humain étant le maillon le plus fragile, ces mesures sont cruciales.

8.3 — A.7 Mesures physiques (14 mesures)

Protègent lieux et matériel : périmètres de sécurité, contrôle d'accès physique, surveillance, protection contre incendie/inondation, sécurité du câblage.

Exemple Marsa Maroc : badges d'accès à la salle serveurs, vidéosurveillance des zones sensibles, protection des câbles reliant les automates.

8.4 — A.8 Mesures technologiques (34 mesures)

Mesures techniques : anti-malware, sauvegardes, chiffrement, sécurité réseau, gestion des correctifs, journalisation, contrôle d'accès logique, développement sécurisé.

Exemple Marsa Maroc : chiffrer les échanges avec la douane, sauvegarder quotidiennement le système de cargaisons, segmenter le réseau pour isoler les automates industriels.

Cours 2 — ISO 9001

Norme : ISO 9001:2015

Niveau : Débutant / Intermédiaire

Pourquoi ce cours ? Un port rend un service : accueillir des navires, décharger/charger, stocker, livrer — vite, en sécurité et sans erreur. La qualité de ce service détermine la satisfaction des clients et la réputation du port. ISO 9001 apporte une méthode pour rendre ce service fiable, constant et sans cesse amélioré. Elle partage la structure (clauses 4 à 10) et la logique PDCA d'ISO 27001 : apprendre l'une facilite l'autre.

Chapitre 0 — Fondamentaux de la qualité

Introduction

0.1 — Qu'est-ce que la qualité ?

La qualité est l'aptitude d'un produit ou service à répondre aux besoins des clients de manière **constante**. Un service de qualité n'est pas parfait une fois, il est fiable à chaque fois. La régularité est au cœur de la notion.

Exemple Marsa Maroc : décharger un navire dans les délais annoncés, sans erreur de cargaison, à chaque escale — voilà la qualité de service.

0.2 — Les 7 principes du management de la qualité

1. **Orientation client** — tout part des besoins du client.
2. **Leadership** — la direction donne le cap et l'exemple.
3. **Implication du personnel** — un personnel compétent et motivé est essentiel.
4. **Approche processus** — gérer l'activité comme des processus reliés.
5. **Amélioration** — progresser en permanence.
6. **Décision fondée sur des preuves** — décider sur des données, pas des impressions.
7. **Management des relations** — bien gérer fournisseurs et partenaires.

0.3 — Le cycle PDCA

Comme ISO 27001 : **Planifier** (objectifs et processus), **Faire** (mettre en œuvre), **Vérifier** (mesurer), **Agir** (corriger et améliorer). Cette boucle tourne en continu et structure les clauses 4 à 10.

0.4 — L'approche par les risques

Depuis 2015, la norme demande d'anticiper les risques et opportunités qui pourraient affecter la qualité, au lieu de seulement réagir après coup.

Chapitre 1 — Contexte de l'organisation

Clause 4

1.1 — Comprendre l'organisation et son contexte

L'organisation identifie les facteurs internes (culture, ressources, savoir-faire) et externes (marché, réglementation, concurrence) qui influencent sa capacité à fournir un service de qualité.

Exemple Marsa Maroc : concurrence d'autres ports, exigences des armateurs internationaux, réglementation douanière marocaine.

1.2 — Besoins des parties intéressées

On identifie les attentes des parties prenantes : clients (rapidité, fiabilité), employés, autorités, fournisseurs, l'État actionnaire. Le système qualité équilibre ces attentes.

1.3 — Périmètre du SMQ

L'organisation définit ce que couvre son système qualité : quels sites, quelles activités. Un périmètre clair rend le système crédible.

1.4 — Le SMQ et ses processus (approche processus)

On voit l'entreprise comme un enchaînement de processus reliés : chacun reçoit des entrées, les transforme, produit des sorties qui alimentent le suivant. On identifie ces processus, leurs interactions et leurs responsables.

Exemple Marsa Maroc : le processus « accostage » alimente « déchargement », puis « stockage », puis « livraison ». Les voir en chaîne permet de repérer où naissent retards et erreurs.

Chapitre 2 — Leadership Clause 5

2.1 — Engagement de la direction

La qualité est portée par le sommet. La direction est responsable de l'efficacité du système : elle s'implique, fixe la politique, alloue les moyens, fait de la satisfaction client une priorité partagée.

2.2 — La politique qualité

Document exprimant les engagements qualité de l'organisation, aligné sur sa stratégie. Il sert de référence à tous et oriente les objectifs.

2.3 — Rôles et responsabilités

La direction attribue clairement qui est responsable de quoi : responsable qualité, pilotes de processus. Chacun connaît son rôle dans la satisfaction du client.

Chapitre 3 — Planification Clause 6

3.1 — Risques et opportunités

On identifie ce qui pourrait empêcher d'atteindre les objectifs qualité (risques) et ce qui pourrait aider (opportunités), puis on planifie des actions.

Exemple Marsa Maroc : risque = panne d'un portique provoquant des retards ; opportunité = nouvelle technologie de suivi des conteneurs.

3.2 — Objectifs qualité

On fixe des objectifs mesurables et cohérents avec la politique (ex. « réduire de 20 % le temps moyen de déchargement »), avec actions, ressources et échéances.

3.3 — Planification des changements

Tout changement (équipement, procédure) est conduit de façon maîtrisée pour ne pas dégrader la qualité pendant la transition.

Chapitre 4 — Support Clause 7

4.1 — Ressources

L'organisation fournit les moyens nécessaires : personnel, infrastructure (quais, engins, systèmes), environnement de travail, moyens de mesure.

4.2 — Compétences et sensibilisation

Le personnel doit être compétent et conscient de sa contribution à la qualité. Un opérateur qui comprend l'impact de son travail fait moins d'erreurs.

4.3 — Communication et informations documentées

La communication est organisée et les informations documentées maîtrisées : bonnes versions, accessibles, protégées, à jour.

Chapitre 5 — Réalisation des activités opérationnelles Clause 8

La clause la plus volumineuse — le « Faire » : la production réelle du service.

5.1 — Planification et maîtrise opérationnelles

On planifie et contrôle les processus qui réalisent le service, dans des conditions maîtrisées (critères, ressources, contrôles).

5.2 — Exigences relatives aux produits et services

Avant de s'engager, l'organisation détermine et revoit les exigences du client : que veut-il, peut-on le fournir ? On évite de promettre l'impossible.

Exemple Marsa Maroc : vérifier, avant d'accepter un navire, qu'on dispose du quai adapté, de la capacité de stockage et des moyens de déchargement requis.

5.3 — Conception et développement

Quand l'organisation conçoit un nouveau service, ce processus est maîtrisé (étapes, revues, validations). Section excluable si l'organisation ne conçoit rien.

5.4 — Maîtrise des prestataires externes

Les fournisseurs et sous-traitants influent sur la qualité finale. On les évalue, les sélectionne et contrôle leurs prestations.

Exemple Marsa Maroc : évaluer un prestataire de maintenance des engins de levage, car sa défaillance affecterait directement le service.

5.5 — Production et prestation de service

Le service est réalisé dans des conditions maîtrisées : procédures claires, personnel qualifié, équipements vérifiés, traçabilité. La qualité se joue ici concrètement.

Chapitre 6 — Évaluation des performances Clause 9

6.1 — Surveillance, mesure et satisfaction client

On suit les performances (délais, erreurs, conformité) et on mesure la satisfaction client (enquêtes, réclamations). Le client est le juge ultime de la qualité.

6.2 — Audit interne

Périodiquement, l'organisation vérifie elle-même la conformité et l'efficacité de son système, pour détecter les écarts avant l'audit externe.

6.3 — Revue de direction

La direction analyse les résultats (indicateurs, audits, satisfaction) et décide des améliorations et ressources. La boucle se referme au sommet.

Chapitre 7 — Amélioration Clause 10

7.1 — Non-conformités et actions correctives

Face à un écart (produit non conforme, réclamation), on le traite **et** on agit sur sa cause pour éviter la récurrence. L'action corrective est un pilier de la norme.

Exemple Marsa Maroc : après une erreur d'affectation de cargaison, on ne corrige pas seulement l'erreur — on revoit la procédure pour qu'elle ne se reproduise plus.

7.2 — Amélioration continue

L'organisation cherche en permanence à améliorer l'efficacité de son système qualité et la satisfaction de ses clients. C'est l'esprit même de la norme.

Note pédagogique. Ce support est reformulé à des fins d'apprentissage et ne reproduit pas le texte officiel protégé des normes. Chaque Cours se mappe sur la table *Cours*, chaque Chapitre (avec son champ *chapitreHLS*) sur *Chapitre*, et chaque sous-section sur *SousChapitre*. Le champ *chapitreHLS* relie une lacune détectée dans un quiz à la clause exacte à réviser, alimentant le moteur adaptatif. Les deux normes partageant la structure des clauses 4 à 10, ce gabarit se réutilise pour ISO 14001 ou ISO 45001.